

Soc Internship day 24

1. What is Ransomware?

Ransomware is a type of malware that encrypts a victim's files or locks access to a system and then demands a ransom payment (usually in cryptocurrency) in exchange for restoring access.

Common Ransomware Attack Flow

1. Initial access (phishing email, malicious link, vulnerable service).
2. Malware execution on the victim's device.
3. Files are encrypted.
4. A ransom note is displayed.
5. Attackers demand payment for a decryption key.

Examples include the historical attacks of WannaCry and LockBit.

2. Indicators of Ransomware Infection

File Indicators

- Files suddenly become inaccessible.
- File extensions change (e.g., .locked, .encrypted).
- Presence of ransom notes such as README.txt or DECRYPT_FILES.html.

System Indicators

- Unusual CPU or disk activity.
- Antivirus software disabled.
- Unexpected system slowdowns.

Network Indicators

- Connections to suspicious IP addresses.
- Large amounts of data being transferred externally.
- Communication with command-and-control (C2) servers.

User Indicators

- Pop-up messages demanding payment.
 - Desktop wallpaper changed to a ransom notice.
 - Inability to open documents.
-

3. Ransomware Response Steps

Step 1: Isolate the System

- Disconnect affected devices from the network.
- Disable Wi-Fi and unplug network cables.
- Prevent spread to other systems.

Step 2: Identify the Infection

- Determine which systems are affected.
- Collect logs and evidence.
- Identify the ransomware variant if possible.

Step 3: Preserve Evidence

- Save ransom notes.
- Capture screenshots.
- Collect system and network logs.

Step 4: Notify the Incident Response Team

- Inform security personnel and management.
- Follow the organization's incident response plan.

Step 5: Eradicate the Threat

- Remove malware using security tools.
- Patch vulnerabilities.
- Reset compromised credentials.

Step 6: Recover Systems

- Restore data from clean backups.
- Verify systems are malware-free before reconnecting.
- Monitor for reinfection.

Step 7: Lessons Learned

- Review how the attack occurred.
- Improve security controls.
- Train users against phishing attacks.

Prevention Tips

- Keep systems patched.
- Use strong endpoint protection.
- Enable multi-factor authentication (MFA).
- Maintain regular offline backups.
- Conduct security awareness training.